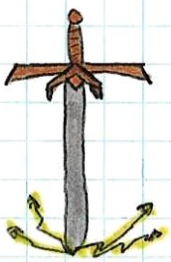
Abuser des fichiers cache :

Pour abuser d'un fichier cache on a besoin des privilèges de lecture sur le fic ces fichiers situé dans /tmp nécessitent souvent des droits root.
- En tant que root on dois alors identifier quels tickets sont présents sur la machine à qui ils appartiennent et leurs dates d'expiration. ~# ls -la /tm
On peux aussi voir à quel groupe appartient un utilisateur pour par exemple cibler des membres du domain admin ~# id julio@domain.htb
Pour importer un fichier cache dans notre session actuelles et l'utiliser il suffit de modifier la variable d'environnement.

```
root@linux01 ~# export KRB5CCNAME = /tmp/fich_ccache
```

Comme avant on peux vérifier l'importation avec klist. Une fois la variable modifié tout les outils réseaux lancé depuis ce même terminal utiliserons automatiquement ce ticket pour s'authentifier.

NB : Si on veux utiliser un fichier ccache sous Windows ou un kirbi sous linux on peux utiliser impacket-ticketConverter pour les convertir il suffit de donner en paramètre le fichier d'"entrée" (le fichier cache) et le nom du fichier final (ex final.kirbi). Et n'oublions pas aussi kinitator qui automatise la rec herche et l'extraction des crédentials AD dans une machine linux.



Pass the Certificate :

PKINIT, abréviation de (Cryptographie à clé publique pour l'authentification initiale) est une extention du protocole kerberos qui permet l'utilisation de la cryptographie à clé publique lors de l'échange d'authentification initiale Le Pass the Certificate fais référence à la technique consistant à utiliser des certificats X509 pour obtenir des TGT. Cette méthodes est principalement utilisé en conjonction avec des attaques contre les services de certificats Active Directory (AD CS) ou d'identifiants fantomes (Shadow Credentials).

Attaque par relais NTLM sur AD CS (ESC8) :

ESC8 est une attack par relais NTLM ciblant un point de terminaison du server AD CS (Active Directory Certificate Service). En effet ce dernier prend en charge l'inscription web qui s'effectue par défault sur HTPP, l'application se trouve par défault sur http://ip.du.server+ADCS/certsrv

- On va utiliser ntlmrelayx d'impacket pour écouter les connexions entr antes et les relayer vers le service d'inscription web avec la commande suivante

```
Agentpalhegens@parrot ~$ impacket-ntlmrelayx -t http://ip.du.AD.CS/certsrv
certfnsh.asp --adcs --smb2support --template KerberosAuthentication
```

--adcs : spécifie à ntlmrelayx que la cible est un serveur ADCS pas un site web standart

--template KerberosAuthentication : C'est le nom du modèle de certificat demandé p l'outil, il peux être différent dans d'autres environnements. Il s'agit simplemen du modèle de certificat utilisé par le controller de domaine pour l'authentification Celui ci peux être enumerer avec des outils comme certipy.

- Une façon de forcer les comptes de machine à s'authentifier auprès d'hotes a bitraires est d'utiliser le bug de l'imprimante (printer bug) cette attaque néces site que le service Spooler d'Impression activé. (Le service est un logiciel Wi dows activé par défault dont le rôle légitime est de gérer la queue et l'envoi des doc